

Glosario Integral de Ciberseguridad

1. Fundamentos Generales de Ciberseguridad

Estos conceptos fundamentales sustentan todas las demás áreas de la seguridad informática. Domínalos primero.

1. CIA Triad (Confidentiality, Integrity, Availability) — El modelo fundamental de seguridad de la información. Confidentiality (Confidencialidad) asegura que los datos solo sean accesibles para partes autorizadas; Integrity (Integridad) garantiza que los datos permanezcan exactos y sin alteraciones; Availability (Disponibilidad) asegura que los sistemas y datos estén accesibles cuando se necesiten.

2. Authentication — El proceso de verificar la identidad de un usuario, dispositivo o sistema. Los métodos comunes incluyen contraseñas, biometría, tokens y certificados criptográficos. Responde a la pregunta: '¿Quién eres?'

3. Authorization — El proceso de determinar qué acciones o recursos puede acceder una entidad autenticada. La Authorization sigue a la Authentication y aplica políticas de control de acceso basadas en roles, atributos o reglas predefinidas.

4. AAA (Authentication, Authorization, and Accounting) — Un marco de seguridad cuyo tercer pilar, Accounting (Auditoría), implica el seguimiento y registro de las actividades de los usuarios y el uso de recursos. Proporciona pistas de auditoría para análisis forense, informes de cumplimiento y detección de acciones no autorizadas.

5. Multi-Factor Authentication (MFA) — Un mecanismo que requiere dos o más factores de verificación independientes: algo que sabes (contraseña), algo que tienes (token/dispositivo) y/o algo que eres (biometría), antes de conceder acceso. El MFA reduce drásticamente el riesgo de credenciales comprometidas.

6. Encryption (Symmetric and Asymmetric) — La conversión de texto plano en texto cifrado ilegible mediante un algoritmo criptográfico y una clave. La Symmetric Encryption (Cifrado Simétrico) usa una sola clave compartida (por ejemplo, AES); la Asymmetric Encryption (Cifrado Asimétrico) usa un par de claves pública/privada (por ejemplo, RSA, ECC).

7. Hashing — Una función criptográfica unidireccional que convierte una entrada de cualquier tamaño en un resumen de longitud fija que no puede revertirse. Se usa para almacenamiento de contraseñas, verificación de integridad y firmas digitales. Algoritmos comunes: SHA-256, SHA-3.

8. Digital Signature — Un mecanismo criptográfico que usa claves asimétricas para verificar autenticidad e integridad. El remitente firma con su clave privada; el destinatario verifica con la clave pública del remitente, proporcionando autenticación, integridad y no repudio.

9. PKI (Public Key Infrastructure) — Un marco de políticas, hardware, software y procedimientos para crear, gestionar, distribuir y revocar certificados digitales. La PKI habilita comunicaciones seguras a través de una cadena de confianza anclada por Autoridades Certificadoras.

10. Digital Certificate — Un documento electrónico emitido por una CA que vincula una clave pública a la identidad de una entidad usando el estándar X.509. Los certificados permiten a las partes verificar las identidades entre sí en comunicaciones cifradas.

11. Certificate Authority (CA) — Una entidad tercera de confianza que emite, valida y revoca certificados digitales dentro de una PKI. Las CA conocidas incluyen DigiCert, Let's Encrypt y GlobalSign.

12. TLS (Transport Layer Security) — Un protocolo criptográfico que proporciona cifrado de extremo a extremo, autenticación e integridad para datos en red, asegurando principalmente HTTPS. La versión actual, TLS 1.3, reemplazó el protocolo SSL obsoleto.

13. SSH (Secure Shell) — Un protocolo criptográfico para inicio de sesión remoto seguro, ejecución de comandos y transferencia de archivos. SSH usa autenticación de clave pública y cifrado simétrico de sesión, reemplazando predecesores inseguros como Telnet.

14. IPsec (Internet Protocol Security) — Un conjunto de protocolos que autentica y cifra paquetes IP en la capa de red (Capa 3). Opera en modo Transport (cifra la carga útil) o modo Tunnel (cifra el paquete completo); ampliamente usado en implementaciones VPN.

15. Non-Repudiation — Una propiedad de seguridad que garantiza que una entidad no pueda negar haber realizado una acción particular. Se logra mediante firmas digitales, registros de auditoría y marcas de tiempo; esencial para cumplimiento legal y regulatorio.

16. OAuth 2.0 — Un marco de autorización abierto que permite a aplicaciones de terceros obtener acceso limitado a recursos de usuario sin exponer credenciales. Usa tokens de acceso y es la base de los flujos 'Iniciar sesión con Google/Facebook'.

17. SAML (Security Assertion Markup Language) — Un estándar basado en XML para intercambiar datos de autenticación y autorización entre un Proveedor de Identidad (IdP) y un Proveedor de Servicios (SP). Habilita el Single Sign-On (SSO) empresarial.

18. OpenID Connect (OIDC) — Una capa de identidad construida sobre OAuth 2.0 que agrega autenticación, permitiendo a los clientes verificar la identidad del usuario y obtener información de perfil usando JSON Web Tokens.

19. JWT (JSON Web Token) — Un formato de token compacto y seguro para URL (RFC 7519) para transmitir afirmaciones de forma segura entre partes. Consta de tres partes codificadas en Base64: encabezado, carga útil y firma.

20. Access Control List (ACL) — Una lista de permisos adjunta a un recurso que especifica qué usuarios o procesos pueden acceder a él y qué operaciones pueden realizar. Un mecanismo fundamental de control de acceso discrecional.

21. RBAC (Role-Based Access Control) — Un modelo de control de acceso que asigna permisos a roles predefinidos en lugar de a usuarios individuales. Los usuarios son asignados a roles (por ejemplo, administrador, editor, espectador), simplificando la gestión a escala.

22. ABAC (Attribute-Based Access Control) — Un modelo flexible que evalúa solicitudes de acceso basándose en atributos del usuario, el recurso, la acción y condiciones ambientales (tiempo, ubicación). Más dinámico y granular que el RBAC.

23. Principle of Least Privilege — Los usuarios, procesos y sistemas deben recibir únicamente el acceso mínimo necesario para realizar sus funciones autorizadas, limitando el impacto ante brechas o errores.

24. Separation of Duties — Las tareas críticas se dividen entre múltiples individuos para que ninguna persona pueda cometer fraude o causar daño importante sin ser detectada. Fundamental en sistemas financieros y marcos de cumplimiento.

25. Defense in Depth — Una estrategia de seguridad en capas que emplea múltiples controles superpuestos a nivel de red, host, aplicación y datos. Si una capa falla, las demás continúan protegiendo los activos.

26. Attack Vector — La ruta o método específico que un actor de amenaza usa para obtener acceso no autorizado: correos de phishing, vulnerabilidades sin parche, credenciales comprometidas, servicios mal configurados, etc.

27. Attack Surface — El conjunto total de posibles puntos de entrada a través de los cuales un atacante podría acceder a los sistemas de una organización. Abarca activos digitales, físicos y elementos humanos; se expande a medida que se adoptan tecnologías.

28. Threat Actor — Cualquier individuo, grupo o entidad que representa una amenaza de ciberseguridad. Categorizado como actores de estado-nación, ciberdelincuentes, hacktivistas, amenazas internas o script kiddies, cada uno con diferentes motivaciones y capacidades.

2. Seguridad Ofensiva

La perspectiva del atacante: desde el reconocimiento hasta la explotación, persistencia y exfiltración.

Conceptos Fundamentales

29. Penetration Testing (Pentesting) — Un ciberataque simulado y autorizado contra un sistema, red o aplicación para evaluar su seguridad. Los pentesters usan las mismas herramientas y técnicas que los atacantes reales, luego producen un informe con hallazgos y orientación de remediación.

30. Vulnerability Assessment — Un proceso sistemático de identificar, cuantificar y priorizar debilidades de seguridad. A diferencia del pentesting, generalmente se detiene en el descubrimiento y clasificación sin explotar activamente las vulnerabilidades.

31. Red Team — Profesionales de seguridad que simulan ataques adversariales del mundo real para probar la detección y respuesta de una organización de manera holística. Los compromisos duran semanas o meses, atacando simultáneamente personas, procesos y tecnología.

32. Exploit — Código, comandos o una técnica que aprovecha una vulnerabilidad específica para causar comportamiento no intencionado, como acceso no autorizado o escalación de privilegios. Puede dirigirse a vulnerabilidades conocidas o de zero-day.

33. Payload — El componente de un exploit que realiza la acción maliciosa real en el objetivo tras una explotación exitosa: iniciar un shell, exfiltrar datos, desplegar malware, etc.

34. Shellcode — Un pequeño fragmento de código máquina usado como payload de un exploit, típicamente diseñado para iniciar un shell de comandos. Escrito en ensamblador e independiente de la posición, se inyecta en la memoria de un proceso en ejecución.

35. Fuzzing (Fuzz Testing) — Una técnica automatizada que alimenta datos inválidos, inesperados o aleatorios a un programa para descubrir bloqueos y errores explotables. Los fuzzers modernos usan estrategias guiadas por cobertura y basadas en mutación.

Reconocimiento y Enumeración

36. Reconnaissance — Passive — Recopilar información del objetivo sin interacción directa: búsquedas WHOIS, redes sociales, registros DNS, páginas en caché. Bajo riesgo de detección.

37. Reconnaissance — Active — Recopilar información interactuando directamente con el objetivo (escaneo, sondeo). Produce datos más ricos pero arriesga detección.

38. OSINT (Open Source Intelligence) — Recolección y análisis de información disponible públicamente desde sitios web, redes sociales, bases de datos gubernamentales y noticias para construir perfiles de objetivos. Una piedra angular de la fase de reconocimiento.

39. Footprinting — Recopilar la máxima información sobre los rangos IP, dominios, empleados, topología de red y stack tecnológico de un objetivo para identificar vectores de ataque.

40. Enumeration — Extraer activamente información detallada: nombres de usuario, recursos compartidos, servicios, tablas de enrutamiento, mediante el establecimiento de conexiones con el objetivo. Va más allá del escaneo para recopilar datos accionables.

41. Port Scanning — Identificar puertos abiertos y servicios en un host enviando paquetes y analizando respuestas. Mapea la superficie de ataque y revela servicios potencialmente vulnerables.

42. Banner Grabbing — Capturar el mensaje de respuesta inicial de un servicio en un puerto abierto para identificar nombres de software, versiones y configuraciones. Permite la coincidencia con vulnerabilidades conocidas.

Técnicas de Explotación

43. Buffer Overflow — Escribir más datos en un búfer de memoria de los que puede contener, sobrescribiendo memoria adyacente. Los atacantes explotan esto para inyectar y ejecutar código arbitrario. Una clase de vulnerabilidad crítica en aplicaciones C/C++.

44. SQL Injection (SQLi) — Insertar SQL malicioso en campos de entrada para manipular una base de datos: leer, modificar o eliminar datos, eludir la autenticación, o lograr ejecución de comandos a nivel de sistema operativo.

45. Cross-Site Scripting (XSS) — Inyectar scripts maliciosos del lado del cliente (típicamente JavaScript) en páginas web vistas por otros usuarios. Variantes: Almacenado, Reflejado y basado en DOM. Usado para robar sesiones, redirigir usuarios o desfigurar sitios.

46. Cross-Site Request Forgery (CSRF) — Forzar al navegador de un usuario autenticado a enviar solicitudes falsificadas a una aplicación vulnerable, realizando acciones no deseadas sin conocimiento del usuario.

47. Command Injection — Explotar una aplicación para ejecutar comandos del sistema operativo arbitrarios pasando entrada no saneada a funciones del sistema como `system()` o `exec()`.

48. Remote Code Execution (RCE) — Una clase de vulnerabilidad que permite a un atacante ejecutar código arbitrario en un objetivo de forma remota a través de una red. Entre los tipos de vulnerabilidad más críticos, a menudo conduce a un compromiso total del sistema.

49. Reverse Shell — Una conexión iniciada desde la máquina víctima hacia el atacante, proporcionando un shell de comandos interactivo. Elude los firewalls que bloquean conexiones entrantes pero permiten salientes.

50. Bind Shell — El objetivo abre un puerto de escucha y espera a que el atacante se conecte. Más fácil de bloquear con firewalls, pero más sencillo de establecer en entornos sin restricciones.

Post-explotación y Movimiento Lateral

51. Privilege Escalation — Vertical — Obtener permisos más altos de los obtenidos inicialmente (por ejemplo, usuario estándar → root/admin) explotando vulnerabilidades del sistema operativo, configuraciones incorrectas o permisos de servicio inseguros.

52. Privilege Escalation — Horizontal — Acceder a recursos de otro usuario con el mismo nivel de privilegio, típicamente mediante fallas en el control de acceso o gestión de sesiones.

53. Lateral Movement — Técnicas usadas para moverse por una red después del acceso inicial, pivotando de un sistema comprometido a otros. Métodos comunes: credenciales robadas, relaciones de confianza, RDP, SMB, PsExec.

54. Persistence — Técnicas para mantener el acceso a través de reinicios y cambios de credenciales: backdoors, nuevas cuentas, scripts de inicio modificados, tareas programadas, modificaciones del registro, rootkits.

55. Pass-the-Hash (PtH) — Usar un hash de contraseña NTLM capturado directamente para autenticarse en sistemas Windows remotos sin descifrar la contraseña en texto plano. Explota la verificación basada en hash de NTLM.

56. Kerberoasting — Solicitar tickets de servicio Kerberos (TGS) para cuentas de Active Directory con Service Principal Names, luego descifrar los hashes de tickets cifrados sin conexión. Cualquier usuario del dominio puede solicitar estos tickets.

57. Living off the Land (LotL / LOLBins) — Usar herramientas de sistema legítimas y preinstaladas (PowerShell, WMI, CertUtil, Rundll32) con fines maliciosos. Extremadamente difícil de detectar porque las herramientas son de confianza del sistema operativo.

58. Pivoting — Usar un sistema comprometido como punto de retransmisión para acceder a redes internas no directamente accesibles desde la posición del atacante. Extiende el alcance del atacante más profundamente en el entorno.

Ingeniería Social

59. Social Engineering — Manipulación psicológica de personas para que realicen acciones o divulguen información confidencial, eludiendo los controles técnicos. Explota sesgos cognitivos: confianza, urgencia, miedo, autoridad.

60. Phishing — Ingeniería social masiva por correo electrónico, suplantando entidades de confianza para engañar a las víctimas para que hagan clic en enlaces maliciosos, abran archivos adjuntos infectados o revelen credenciales. El vector de ataque inicial más común.

61. Spear Phishing — Phishing altamente dirigido a un individuo u organización específica, usando información personalizada obtenida mediante OSINT. Significativamente más efectivo que las campañas genéricas.

62. Whaling — Spear Phishing dirigido a ejecutivos de alto nivel (C-suite), miembros de la junta directiva o alta dirección. Se enfoca en acciones de alto valor como transferencias bancarias o divulgación de datos corporativos sensibles.

63. Vishing (Voice Phishing) — Ingeniería social por teléfono o VoIP, suplantando bancos, soporte técnico o agencias gubernamentales para extraer información sensible.

64. Smishing (SMS Phishing) — Mensajes de texto engañosos que contienen enlaces maliciosos o indicaciones para llamar a números fraudulentos. Explota la percepción de confiabilidad de los SMS.

Ataques a Credenciales

65. Password Cracking — Recuperar contraseñas en texto plano a partir de hashes o almacenes cifrados usando fuerza bruta, diccionarios, tablas arcoíris o mutaciones basadas en reglas. Herramientas clave: Hashcat, John the Ripper.

66. Brute Force Attack — Probar sistemáticamente cada posible combinación de caracteres hasta encontrar la contraseña correcta. Éxito garantizado eventualmente, pero computacionalmente costoso para contraseñas complejas.

67. Dictionary Attack — Usar una lista de palabras precompilada de contraseñas probables en lugar de combinaciones exhaustivas. Más rápido que la fuerza bruta, pero limitado a contraseñas en (o derivables de) la lista.

68. Rainbow Table — Una tabla de búsqueda precomputada que mapea hashes a textos planos para búsqueda inversa rápida. Resulta ineficaz ante algoritmos de hash con sal (salted hashing).

69. Credential Stuffing — Prueba automatizada de pares de nombre de usuario/contraseña filtrados de brechas previas contra otros servicios. Explota la reutilización generalizada de contraseñas.

Ataques de Red y Suplantación

70. Man-in-the-Middle (MITM) — Interceptar y potencialmente alterar secretamente las comunicaciones entre dos partes que creen estar comunicándose directamente. Usado para espionaje, robo de credenciales e inyección de contenido.

71. Session Hijacking — Tomar el control de una sesión activa robando o prediciendo un token de sesión válido, permitiendo la suplantación del usuario legítimo.

72. ARP Spoofing — Enviar mensajes ARP falsificados en una LAN para asociar la dirección MAC del atacante con una IP legítima (por ejemplo, la puerta de enlace), redirigiendo el tráfico para ataques MITM.

73. DNS Spoofing (DNS Cache Poisoning) — Inyectar registros DNS falsificados en la caché de un resolutor, redirigiendo a los usuarios a servidores controlados por el atacante. Usado para phishing, distribución de malware e interceptación de tráfico.

74. IP Spoofing — Crear paquetes IP con una dirección de origen falsificada para suplantar otro sistema o eludir controles de acceso basados en IP. Común en ataques de amplificación DDoS.

Vectores de Entrega Web

75. Watering Hole Attack — Comprometer sitios web visitados frecuentemente por el grupo objetivo e inyectar código malicioso. Aprovecha la confianza en sitios legítimos y familiares.

76. Drive-by Download — Malware descargado e instalado automáticamente simplemente al visitar un sitio web comprometido o malicioso, a menudo sin interacción del usuario, explotando vulnerabilidades del navegador o plugins.

77. Exploit Kit — Un conjunto de herramientas preempaquetado que automatiza la explotación de vulnerabilidades del lado del cliente en navegadores y plugins. Identifica el software de la víctima, selecciona un exploit y entrega un payload.

Herramientas Ofensivas Clave

78. Metasploit — Un framework de pruebas de penetración de código abierto que proporciona módulos de exploit, payloads (incluyendo Meterpreter), codificadores y módulos auxiliares para reconocimiento y post-explotación.

79. Nmap (Network Mapper) — Una herramienta de código abierto para descubrimiento de redes y auditoría de seguridad: descubrimiento de hosts, escaneo de puertos, detección de servicios/versiones, identificación de sistema operativo y scripting NSE.

80. Burp Suite — Una plataforma integrada para pruebas de seguridad de aplicaciones web: proxy de interceptación HTTP(S), escaneo automatizado y herramientas manuales (Repeater, Intruder, Decoder).

3. Seguridad Defensiva

El arsenal del defensor: detección, respuesta, análisis forense e inteligencia.

Operaciones de Seguridad

81. Security Operations Center (SOC) — Una instalación centralizada dotada de analistas que monitorean, detectan, analizan y responden continuamente a incidentes de ciberseguridad. El centro neurálgico de las operaciones defensivas, aprovechando SIEM, EDR e inteligencia de amenazas.

82. SIEM (Security Information and Event Management) — Una plataforma que recopila, agrega, correlaciona y analiza registros y eventos de seguridad de diversas fuentes para detectar amenazas y apoyar el cumplimiento. Los SIEM modernos incorporan UEBA y aprendizaje automático.

83. EDR (Endpoint Detection and Response) — Una solución que monitorea dispositivos de punto final en tiempo real, registrando actividades para detectar comportamiento sospechoso. Usa análisis conductual y puede aislar automáticamente endpoints comprometidos.

84. XDR (Extended Detection and Response) — Evolución del EDR que unifica la telemetría de endpoints, red, nube, correo electrónico e identidad en una sola plataforma. Proporciona visibilidad holística y respuesta automatizada coordinada.

85. MDR (Managed Detection and Response) — Un servicio externalizado que combina tecnología avanzada de detección con análisis experto humano para monitoreo de amenazas 24/7, investigación y respuesta a incidentes.

86. SOAR (Security Orchestration, Automation, and Response) — Soluciones que integran herramientas de seguridad y automatizan flujos de trabajo de respuesta a incidentes mediante playbooks predefinidos. Orquesta acciones como bloquear IPs, poner en cuarentena endpoints y enriquecer alertas.

87. NDR (Network Detection and Response) — Monitoreo de tráfico de red en tiempo real usando ML y análisis conductual para detectar amenazas como movimiento lateral, exfiltración y comunicaciones C2.

88. Log Analysis — Examinar datos de registro de sistemas, aplicaciones y herramientas de seguridad para identificar anomalías, violaciones de políticas e indicadores de compromiso. Fundamental para la detección, el análisis forense y el cumplimiento.

Técnicas de Detección

89. Signature-based Detection — Comparar datos observados contra una base de datos de firmas de amenazas conocidas. Muy preciso para amenazas conocidas, pero no puede detectar malware nuevo o polimórfico.

90. Behavioral Analysis / Heuristic Detection — Identificar amenazas analizando el comportamiento en lugar de firmas conocidas. Usa reglas y algoritmos para marcar características sospechosas, permitiendo la detección de variantes desconocidas.

91. Anomaly Detection — Establecer líneas base de comportamiento normal y marcar desviaciones significativas. Puede identificar amenazas nuevas y ataques internos, pero puede producir tasas más altas de falsos positivos.

92. Sandboxing — Ejecutar archivos sospechosos en un entorno virtual aislado para observar el comportamiento de forma segura. Revela acciones maliciosas (conexiones de red, cambios de archivos, modificaciones del registro) sin arriesgar los sistemas de producción.

93. Static Analysis — Examinar malware sin ejecutarlo: desensamblado, extracción de cadenas, análisis de cabeceras. Un primer paso rápido en el triaje de malware.

94. Dynamic Analysis — Ejecutar malware en un entorno controlado para observar el comportamiento en tiempo de ejecución: creación de procesos, cambios en el sistema de archivos, comunicaciones de red. Revela las capacidades reales.

95. Reverse Engineering — Deconstruir software compilado para entender su funcionamiento interno a nivel ensamblador. Esencial para analizar malware sofisticado y desarrollar firmas de detección.

96. YARA Rules — Un lenguaje de coincidencia de patrones de código abierto para identificar y clasificar malware basado en cadenas de texto, patrones binarios y lógica booleana. Permite la detección en archivos, memoria y flujos de datos.

97. Sigma Rules — Un formato de reglas de detección basado en YAML y neutral para proveedores para sistemas SIEM. Convertible en consultas específicas de plataforma (Splunk, Elastic, Sentinel), complementando la coincidencia de archivos de YARA.

Inteligencia de Amenazas

98. Threat Intelligence — Conocimiento basado en evidencia sobre amenazas existentes o emergentes: contexto, mecanismos, indicadores y asesoramiento práctico, que informa la defensa proactiva y la asignación de recursos.

99. Cyber Threat Intelligence (CTI) — La disciplina estructurada de recopilar, procesar y difundir información sobre adversarios. Categorizada como estratégica, táctica, operacional o técnica.

100. Indicators of Compromise (IOC) — Artefactos observables (IPs maliciosas, hashes de archivos, dominios, claves de registro) que indican que un sistema ha sido comprometido. Reactivos: usados para detección y respuesta después del compromiso.

101. Indicators of Attack (IOA) — Patrones conductuales que señalan un ataque activo en progreso, enfocándose en la intención y las técnicas en lugar de artefactos específicos. Proactivos y orientados a técnicas.

102. STIX (Structured Threat Information eXpression) — Un lenguaje basado en JSON para representar y compartir inteligencia de amenazas en formato legible por máquina. Modela datos como objetos interconectados: indicadores, malware, campañas, actores de amenaza.

103. TAXII (Trusted Automated eXchange of Intelligence Information) — Un protocolo complementario a STIX para transportar de forma segura inteligencia de amenazas sobre HTTPS. Soporta modelos de intercambio hub-and-spoke, peer-to-peer y fuente/suscriptor.

104. Threat Intelligence Platform (TIP) — Un sistema que agrega, correlaciona, enriquece y operacionaliza la inteligencia de amenazas de múltiples fuentes. Distribuye IOCs a herramientas defensivas y proporciona contexto para las decisiones.

105. Cyber Kill Chain (Lockheed Martin) — Un modelo de siete fases de un ciberataque: Reconocimiento → Armamento → Entrega → Explotación → Instalación → Comando y Control → Acciones sobre Objetivos. Permite a los defensores interrumpir los ataques en cada etapa.

Equipos Defensivos

106. Blue Team — El grupo de seguridad defensiva responsable del monitoreo, detección, respuesta a incidentes, gestión de vulnerabilidades y hardening de seguridad. Opera SOCs y gestiona herramientas defensivas.

107. Purple Team — Una función colaborativa que integra las operaciones del Red Team y el Blue Team mediante conocimiento compartido, retroalimentación en tiempo real y ejercicios coordinados. Garantiza que las simulaciones de ataque mejoren directamente las defensas.

108. Threat Hunting — Búsqueda proactiva dirigida por analistas a través de redes y conjuntos de datos para detectar amenazas avanzadas que evaden los controles automatizados. Basada en hipótesis de inteligencia, análisis e indicadores de anomalías.

Respuesta a Incidentes

109. Incident Response (IR) — El proceso estructurado de identificar, gestionar, contener y recuperarse de incidentes de ciberseguridad. Sigue marcos como NIST SP 800-61 y SANS, ejecutado por CSIRTs.

110. Incident Response Plan (IRP) — Un documento formal que define roles, responsabilidades, protocolos de comunicación, rutas de escalamiento y pasos técnicos para responder a incidentes. Se prueba regularmente mediante ejercicios.

111. Triage — Evaluación y priorización inicial de alertas para determinar severidad, alcance, legitimidad y urgencia. Asegura que las amenazas más críticas reciban atención inmediata.

112. Containment — Limitar la propagación e impacto de un incidente aislando sistemas afectados, bloqueando comunicaciones maliciosas y deshabilitando cuentas comprometidas. Incluye estrategias a corto y largo plazo.

113. Eradication — Eliminar completamente todos los rastros de una amenaza: malware, backdoors, cuentas comprometidas, y parchear las vulnerabilidades explotadas.

114. Recovery — Restaurar los sistemas afectados a operación normal desde respaldos limpios, con monitoreo mejorado para detectar recurrencias.

115. Lessons Learned / Post-Incident Review — Una retrospectiva realizada tras la resolución del incidente para evaluar la respuesta, identificar mejoras y actualizar planes, controles y capacitación.

116. Chain of Custody — Un registro documentado que rastrea el manejo y almacenamiento de evidencia digital desde la recolección hasta los procedimientos legales. Esencial para preservar la integridad y admisibilidad de la evidencia.

Análisis Forense Digital

117. Digital Forensics — La aplicación de métodos científicamente validados para identificar, preservar, recopilar, examinar y presentar evidencia digital. Apoya la respuesta a incidentes, investigaciones penales y cumplimiento regulatorio.

118. Disk Imaging — Crear una copia forense bit a bit de un dispositivo de almacenamiento (incluyendo archivos eliminados y espacio no asignado) usando herramientas como FTK Imager o EnCase. La verificación de hash garantiza la integridad.

119. Memory Forensics — Analizar la memoria volátil (RAM) para extraer procesos en ejecución, conexiones de red, claves de cifrado y código inyectado. Crítico para investigar malware sin archivos y rootkits que operan completamente en memoria.

120. Network Forensics — Capturar y analizar el tráfico de red para detectar intrusiones y reconstruir cronologías de ataques. Examina PCAPs, datos de flujo y registros DNS.

121. Malware Analysis — Estudiar software malicioso (mediante técnicas de análisis estático, dinámico y de ingeniería inversa) para comprender su funcionalidad, origen e impacto. Informa las firmas de detección y la remediación.

Seguridad de Endpoints y Tecnología de Engaño

122. Endpoint Security — Asegurar los dispositivos que sirven como puntos de entrada a la red: equipos de escritorio, laptops, servidores, móviles, IoT. Abarca antivirus, EDR, firewalls de host, control de aplicaciones y cifrado.

123. Antivirus / Antimalware — Software que detecta y elimina software malicioso. Los motores tradicionales usan firmas; las soluciones modernas añaden detección heurística, conductual, ML y basada en nube.

124. Data Loss Prevention (DLP) — Herramientas y estrategias que identifican, monitorean y protegen datos sensibles en reposo, en movimiento y en uso. Bloquea o cifra automáticamente las transferencias que violan las políticas de seguridad.

125. Honeypot — Un sistema señuelo que imita un objetivo legítimo para atraer atacantes. Recopila inteligencia sobre TTPs y sirve como alerta temprana. Clasificados como de baja interacción (simulado) o alta interacción (SO completo).

126. Honeynet — Una red de honeypots interconectados que simula un entorno de producción completo, permitiendo observar patrones de ataque complejos en múltiples sistemas.

127. Canary Token — Un artefacto engañoso ligero (documento falso, URL, credencial, clave API) que activa una alerta cuando se accede. Prácticamente cero falsos positivos: cualquier interacción señala actividad maliciosa.

128. Deception Technology — Soluciones que despliegan señuelos, cebos e indicadores en todo el entorno. Las plataformas modernas automatizan el despliegue, se integran con SIEM/SOAR y proporcionan alertas de alta fidelidad.

Divulgación y Gestión de Vulnerabilidades

129. Vulnerability Disclosure — Reportar vulnerabilidades descubiertas al proveedor afectado siguiendo políticas (alineadas con ISO 29147) que equilibran informar a los defensores con dar tiempo a los proveedores para parchear.

130. Bug Bounty — Programas que incentivan a investigadores externos a encontrar y reportar responsablemente vulnerabilidades a cambio de recompensas. Plataformas: HackerOne, Bugcrowd, Intigriti.

131. Threat Modeling — Una metodología estructurada para identificar y priorizar amenazas potenciales analizando superficies de ataque, actores de amenaza y vulnerabilidades. Marcos de trabajo: STRIDE, PASTA, VAST.

4. Administración de la Seguridad

Gobernanza, riesgo, cumplimiento y las estructuras organizacionales que hacen funcionar la seguridad.

Marcos y Estándares

132. NIST Cybersecurity Framework (CSF) — Un marco voluntario del Instituto Nacional de Estándares y Tecnología para gestionar el riesgo de ciberseguridad. CSF 2.0 (febrero de 2024) se construye en torno a seis funciones centrales: Govern, Identify, Protect, Detect, Respond, Recover, con nuevo énfasis en gobernanza y riesgo de la cadena de suministro.

133. ISO 27001 — El estándar internacional que especifica los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI). Las organizaciones pueden certificarse demostrando gestión sistemática de riesgos mediante políticas y controles definidos.

134. ISO 27002 — Un estándar complementario que proporciona un conjunto de referencia de controles de seguridad y orientación de implementación para los controles listados en el Anexo A de ISO 27001.

135. COBIT (Control Objectives for Information and Related Technologies) — Un marco de gobernanza de TI de ISACA que alinea los objetivos de TI con los objetivos del negocio. COBIT 2019 cubre procesos, estructuras organizacionales y políticas para la gestión empresarial de TI.

136. PCI DSS (Payment Card Industry Data Security Standard) — Estándares de seguridad del PCI Security Standards Council para proteger los datos de titulares de tarjetas. Prescribe 12 áreas de requisitos que cubren seguridad de red, control de acceso, cifrado y monitoreo.

137. GDPR (General Data Protection Regulation) — La regulación integral de protección de datos de la UE (2018) que rige los datos personales de residentes de la UE. Exige minimización de datos, consentimiento, derechos individuales e impone multas de hasta el 4% de la facturación global anual.

138. SOC 2 (Service Organization Control 2) — Un marco de auditoría de AICPA que evalúa los controles frente a cinco criterios de confianza: Seguridad, Disponibilidad, Integridad del Procesamiento, Confidencialidad y Privacidad. Los informes SOC 2 Tipo II son ampliamente requeridos para proveedores SaaS y en la nube.

Gestión del Riesgo

139. Risk Management — El proceso continuo de identificar, evaluar, priorizar y mitigar riesgos para los activos organizacionales. Abarca identificación de amenazas, análisis de vulnerabilidades, evaluación de impacto e implementación de controles.

140. Risk Assessment — Identificar sistemáticamente amenazas y vulnerabilidades, analizando probabilidad e impacto. Puede ser cualitativo (escalas descriptivas), cuantitativo (probabilidades numéricas) o híbrido.

141. Risk Appetite / Risk Tolerance — El Risk Appetite es el nivel amplio de riesgo que una organización acepta en la búsqueda de sus objetivos; la Risk Tolerance define límites específicos y medibles. Juntos guían las decisiones de inversión en seguridad.

142. GRC (Governance, Risk, and Compliance) — Un enfoque integrado que coordina las estructuras de gobernanza, la gestión de riesgos y las actividades de cumplimiento. Las plataformas GRC ayudan a alinear la seguridad con los objetivos del negocio y a agilizar la adherencia regulatoria.

Políticas y Planificación

143. Security Policy — Un documento formal que define objetivos de seguridad, roles, responsabilidades, comportamiento aceptable y reglas que rigen la protección de activos de información. El fundamento del cual derivan los estándares y procedimientos.

144. Acceptable Use Policy (AUP) — Describe los usos permitidos y prohibidos de los recursos de TI de la organización. Establece expectativas para el comportamiento de los empleados y especifica las consecuencias por violaciones.

145. Disaster Recovery Plan (DRP) — Procedimientos documentados para restaurar sistemas de TI críticos tras un evento disruptivo. Define Recovery Time Objectives (RTO), Recovery Point Objectives (RPO), estrategias de respaldo y protocolos de comunicación.

146. Business Continuity Plan (BCP) — Un plan integral para mantener las funciones empresariales esenciales durante y después de una interrupción. Más amplio que el DRP, cubre personal, instalaciones, cadenas de suministro y comunicaciones.

147. Business Impact Analysis (BIA) — Identifica y evalúa los efectos potenciales de las interrupciones: pérdidas financieras, tiempo de inactividad operativa, daño reputacional, consecuencias regulatorias. Informa directamente las prioridades del DRP y BCP.

148. IT/Security Governance — El sistema de políticas, estructuras y procesos mediante los cuales el liderazgo dirige y monitorea las actividades de TI y seguridad. Establece responsabilidades y asegura que el riesgo de ciberseguridad sea parte de la gestión de riesgos empresariales.

149. Tabletop Exercise — Una simulación basada en discusión donde las partes interesadas recorren un escenario hipotético de incidente. Identifica brechas procedimentales y mejora la coordinación sin interrumpir las operaciones.

Gestión de Vulnerabilidades

150. Vulnerability Management Program — Un proceso continuo de identificar, clasificar, priorizar, remediar y validar vulnerabilidades de seguridad. Involucra escaneo, correlación de inteligencia de amenazas, priorización basada en riesgo y despliegue de parches.

151. CVSS (Common Vulnerability Scoring System) — Un marco abierto que califica la severidad de vulnerabilidades de 0.0 a 10.0. CVSS v4.0 (noviembre de 2023) usa grupos de métricas Base, Amenaza, Ambiental y Suplementaria.

152. CVE (Common Vulnerabilities and Exposures) — Un sistema de ID estandarizado (por ejemplo, CVE-2024-12345) mantenido por MITRE para vulnerabilidades divulgadas públicamente. Proporciona una referencia común en herramientas y organizaciones.

153. CWE (Common Weakness Enumeration) — Una taxonomía de MITRE que clasifica las causas raíz de las vulnerabilidades (por ejemplo, CWE-79 para XSS, CWE-89 para SQLi). Mientras que CVE identifica instancias específicas, CWE categoriza tipos de debilidades subyacentes.

154. NVD (National Vulnerability Database) — La base de datos integral de NIST sincronizada con CVE. Enriquece las entradas con puntuaciones CVSS, clasificaciones CWE, información de productos afectados (CPE) y referencias de parches.

155. Patch Management — Identificar, adquirir, probar e implementar actualizaciones de software para abordar vulnerabilidades conocidas. Los programas eficaces priorizan por severidad, prueban en entornos de pruebas y rastrean el despliegue en toda la organización.

Otros Conceptos de Gestión

156. SLA (Service Level Agreement) — Un contrato que define expectativas de rendimiento medibles: tiempo de actividad, tiempos de respuesta, requisitos de seguridad y penalizaciones por incumplimiento.

157. Asset Management — Identificar, inventariar, clasificar y rastrear todos los recursos de hardware, software, datos y red. No se puede proteger lo que no se sabe que existe.

158. Data Classification — Categorizar datos por sensibilidad (público, interno, confidencial, restringido). Permite controles de seguridad proporcionales y procedimientos de manejo.

159. Security Audit — Una evaluación sistemática de controles de seguridad, políticas y procedimientos frente a estándares establecidos. Puede ser interna o externa; produce hallazgos y recomendaciones.

160. Third-Party Risk Management (TPRM) — Evaluar y monitorear los riesgos de ciberseguridad provenientes de proveedores, suministradores y socios con acceso a los sistemas o datos de la organización. Involucra cuestionarios de diligencia debida, requisitos contractuales y monitoreo continuo.

161. Supply Chain Risk Management (SCRM) — Identificar y mitigar riesgos de la cadena de suministro de hardware, software y servicios: actualizaciones comprometidas, componentes falsificados, inserción de código malicioso. Enfatizado en NIST CSF 2.0.

162. PTaaS (Penetration Testing as a Service) — Pentesting continuo o bajo demanda a través de una plataforma de servicio, combinando escaneo automatizado con pruebas expertas manuales y resultados en tiempo real.

163. Security Awareness Training — Educación continua que enseña a los empleados a reconocer y reportar amenazas como phishing e ingeniería social. Combina módulos de formación, ataques simulados y evaluaciones.

5. Monitorización y Arquitecturas de Seguridad

Controles de red, seguridad en la nube y los patrones arquitectónicos que protegen la infraestructura moderna.

Controles de Red

164. Firewall — Un dispositivo que monitorea y controla el tráfico basado en reglas. Los firewalls sin estado filtran solo por información de cabecera; los firewalls con estado rastrean conexiones; los NGFW (Next-Generation Firewalls) añaden inspección de capa de aplicación, IPS integrado e inteligencia de amenazas.

165. IDS (Intrusion Detection System) — Monitorea el tráfico de red o la actividad del host en busca de comportamiento malicioso. Opera de forma pasiva: detecta y alerta pero no bloquea amenazas.

166. IPS (Intrusion Prevention System) — Se sitúa en línea con el tráfico y bloquea activamente las amenazas detectadas descartando paquetes, bloqueando conexiones o reiniciando sesiones. Extiende el IDS con prevención automatizada.

167. WAF (Web Application Firewall) — Filtra el tráfico HTTP/HTTPS para proteger las aplicaciones web contra ataques de capa de aplicación (SQLi, XSS, CSRF). Inspecciona solicitudes y respuestas frente a conjuntos de reglas configurables.

168. NAC (Network Access Control) — Aplica políticas sobre qué dispositivos y usuarios pueden conectarse a una red. Autentica y evalúa la postura de seguridad del dispositivo (parches, antivirus) antes de conceder acceso; pone en cuarentena los dispositivos no conformes.

169. Network Segmentation — Dividir una red en subredes más pequeñas y aisladas para limitar el movimiento lateral, contener brechas y habilitar la aplicación granular de políticas.

170. Microsegmentation — Segmentación granular a nivel de carga de trabajo dentro de centros de datos o entornos en la nube. Aplica políticas por carga de trabajo, aplicación o proceso individual: mucho más precisa que la segmentación por subred/VLAN.

171. DMZ (Demilitarized Zone) — Un segmento perimetral entre la red interna e internet que aloja servicios de cara al público (servidores web, puertas de enlace de correo). Los firewalls en ambos lados controlan el flujo de tráfico.

Acceso Remoto y Conectividad

172. VPN (Virtual Private Network) — Crea un túnel cifrado sobre una red pública para acceso remoto seguro. Usa IPSec, SSL/TLS o WireGuard. Cada vez más complementado por ZTNA.

173. Proxy Server — Un intermediario que reenvía las solicitudes de los clientes a internet. Proporciona almacenamiento en caché, filtrado de contenido, anonimización y registro.

174. Reverse Proxy — Se sitúa delante de los servidores backend, interceptando las solicitudes entrantes. Proporciona balanceo de carga, terminación SSL, almacenamiento en caché y oculta las identidades del backend.

175. Load Balancer — Distribuye el tráfico entre múltiples servidores backend para optimizar el rendimiento y garantizar la alta disponibilidad. También proporciona monitoreo de estado, descarga SSL y absorción de DDoS.

176. Bastion Host / Jump Server — Un servidor reforzado que sirve como el único punto de entrada administrativo a una red privada. Ejecuta servicios mínimos; todas las sesiones se enrutan a través de él para registro centralizado y control.

Marcos Arquitectónicos Modernos

177. Zero Trust Architecture (ZTA) — Un modelo de seguridad: 'nunca confíes, siempre verifica'. Requiere verificación continua de cada usuario y dispositivo, aplica el mínimo privilegio, microsegmentación, y asume que cualquier componente puede estar ya comprometido.

178. ZTNA (Zero Trust Network Access) — Tecnologías que proporcionan acceso basado en identidad y de mínimo privilegio a aplicaciones específicas (no acceso amplio a la red).

Deniega por defecto, verificando identidad y postura del dispositivo. Cada vez más reemplaza las VPN tradicionales.

179. SASE (Secure Access Service Edge) — Una arquitectura nativa en la nube (Gartner, 2019) que converge SD-WAN con servicios de seguridad (SWG, CASB, ZTNA, FWaaS) en una plataforma unificada y distribuida globalmente.

180. SSE (Security Service Edge) — El subconjunto de seguridad de SASE (sin SD-WAN): consolida SWG, CASB, ZTNA y FWaaS en una sola plataforma entregada en la nube. Definido por Gartner en 2021.

181. SD-WAN (Software-Defined Wide Area Network) — Usa principios de red definida por software para gestionar conexiones WAN a través de múltiples tipos de transporte. Proporciona gestión centralizada, enrutamiento inteligente y forma la mitad de red de SASE.

Seguridad en la Nube

182. Cloud Security — Políticas, tecnologías y controles que protegen los entornos en la nube (IaaS, PaaS, SaaS). Opera bajo un modelo de responsabilidad compartida: el proveedor asegura la infraestructura; el cliente asegura los datos, configuraciones y accesos.

183. CASB (Cloud Access Security Broker) — Un punto de aplicación de políticas entre consumidores y proveedores de servicios en la nube. Proporciona visibilidad del uso de la nube, aplica seguridad de datos, detecta amenazas y ofrece DLP, cifrado y detección de anomalías.

184. CSPM (Cloud Security Posture Management) — Monitorea continuamente las configuraciones de la nube para identificar configuraciones incorrectas, violaciones de cumplimiento y riesgos de seguridad. Puede automatizar recomendaciones de remediación.

185. CWPP (Cloud Workload Protection Platform) — Protege las cargas de trabajo en la nube (VMs, contenedores, serverless) en nubes públicas, privadas e híbridas. Ofrece escaneo de vulnerabilidades, protección en tiempo de ejecución, monitoreo de integridad y lista blanca de aplicaciones.

Gestión de Identidades y Acceso Privilegiado

186. IAM (Identity and Access Management) — Un marco que gestiona las identidades digitales y controla el acceso a los recursos. Abarca autenticación (SSO, MFA, biometría), autorización (RBAC/ABAC) y gestión del ciclo de vida de usuarios.

187. PAM (Privileged Access Management) — Asegurar, controlar, monitorear y auditar las cuentas privilegiadas (administradores, root, cuentas de servicio). Proporciona bóveda de contraseñas, grabación de sesiones, acceso justo a tiempo y aplicación del mínimo privilegio.

Monitorización de Red

188. Network Monitoring — Observación continua del tráfico de red, el rendimiento y la disponibilidad usando herramientas y protocolos (SNMP, ICMP) para detectar anomalías e incidentes de seguridad.

189. NetFlow / sFlow — Protocolos que exportan metadatos sobre flujos de tráfico IP. NetFlow (Cisco) y sFlow (estándar de la industria, muestreo estadístico) permiten el análisis de ancho de banda, detección de anomalías y análisis forense sin captura completa de paquetes.

190. Packet Capture (PCAP) — Interceptar y registrar paquetes de red completos para su análisis usando herramientas como Wireshark o tcpdump. Proporciona el nivel más profundo de visibilidad de red.

191. Deep Packet Inspection (DPI) — Examinar tanto la cabecera como la carga útil de los paquetes en la capa de aplicación. Permite la identificación de aplicaciones, detección de malware, DLP y filtrado de contenido.

192. SSL/TLS Inspection — Interceptar el tráfico HTTPS cifrado, descifrarlo para la inspección de amenazas y luego volver a cifrarlo antes de reenviarlo. Crítico para mantener visibilidad en el creciente volumen de tráfico cifrado.

193. Network TAP (Test Access Point) — Un dispositivo hardware pasivo que crea una copia exacta de todo el tráfico en un enlace para las herramientas de monitoreo. Preferido sobre los puertos SPAN/mirror por captura de plena fidelidad sin pérdidas.

194. Air Gap — Aislamiento físico de una computadora o red de todas las redes no seguras. Usado para sistemas clasificados e infraestructura crítica, aunque sigue siendo vulnerable a amenazas internas y ataques de acceso físico.

195. Security Architecture — El diseño general de la infraestructura de seguridad de una organización: tecnologías, procesos, estándares y principios que definen cómo se implementan e integran los controles.

6. MITRE ATT&CK y OWASP

Marcos de referencia de la industria que proporcionan un lenguaje común para amenazas y vulnerabilidades.

MITRE ATT&CK

196. MITRE ATT&CK Framework — Una base de conocimiento curada de TTPs adversariales basada en observaciones del mundo real, organizada en matrices para Enterprise, Mobile e ICS. Usado para mapeo de detección, análisis de brechas, red teaming e inteligencia de amenazas.

197. Tactics (MITRE) — El objetivo táctico del adversario: el 'por qué' detrás de una acción. La matriz Enterprise incluye 14 tácticas: Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact, Reconnaissance y Resource Development.

198. Techniques (MITRE) — Describen 'cómo' un adversario logra una táctica. Cada táctica contiene múltiples técnicas (por ejemplo, Phishing bajo Initial Access), muchas con sub-técnicas para mayor detalle granular.

199. TTPs (Tactics, Techniques, and Procedures) — Los patrones conductuales de los actores de amenaza. Tactics = objetivos, Techniques = métodos, Procedures = implementaciones específicas observadas en el campo. Centrales para la inteligencia de amenazas y el perfil de adversarios.

OWASP

200. OWASP (Open Web Application Security Project) — Una organización sin fines de lucro global que produce herramientas de código abierto lideradas por la comunidad, documentación y estándares para la seguridad del software. Los recursos incluyen el OWASP Top 10, ASVS y guías de pruebas.

201. OWASP Top 10 (2021) — Los diez riesgos de seguridad más críticos en aplicaciones web: A01-Control de Acceso Roto, A02-Fallos Criptográficos, A03-Inyección, A04-Diseño Inseguro, A05-Mala Configuración de Seguridad, A06-Componentes Vulnerables y Desactualizados, A07-Fallos de Identificación y Autenticación, A08-Fallos de Integridad de Software y Datos, A09-Fallos de Registro y Monitoreo de Seguridad, A10-SSRF.

202. Broken Access Control (A01) — Fallos en la aplicación de permisos de usuario, permitiendo acceso no autorizado a funcionalidades o datos, modificación de datos o escalación de privilegios.

203. Cryptographic Failures (A02) — Anteriormente llamado 'Exposición de Datos Sensibles'. Cubre algoritmos débiles, gestión inadecuada de claves, transmisión en texto claro y ausencia de cifrado en reposo o en tránsito.

204. Injection (A03) — Datos no confiables enviados a un intérprete como parte de un comando o consulta: SQLi, inyección NoSQL, inyección de comandos OS, inyección LDAP. El XSS ahora está integrado en esta categoría.

205. Insecure Design (A04) — Introducida en 2021, se centra en fallas arquitectónicas fundamentales en lugar de errores de implementación. No puede corregirse con una implementación perfecta: requiere modelado de amenazas y patrones de diseño seguros.

206. Security Misconfiguration (A05) — Configuraciones de seguridad incorrectas: credenciales predeterminadas, almacenamiento en la nube abierto, servicios innecesarios, mensajes de error verbosos, CORS permisivo. Una de las categorías más frecuentemente encontradas.

207. Server-Side Request Forgery — SSRF (A10) — Una vulnerabilidad donde una aplicación web recupera recursos remotos de una URL proporcionada por el usuario sin validación, habilitando el acceso a servicios internos, metadatos de instancias en la nube o escaneo de redes internas.

7. Tipos de Malware y Amenazas, y Términos Emergentes 2024–2025

Desde las categorías clásicas de amenazas hasta la vanguardia de la seguridad en la era de la IA.

Tipos de Malware y Amenazas Clásicas

208. Malware — Término general para software malicioso. Los tipos principales incluyen: Virus (autorreplicante, se adjunta a programas), Worm (se autopropaga por redes), Trojan (disfrazado de software legítimo), Rootkit (se oculta profundamente en el SO para acceso persistente), Spyware (monitorea actividad secretamente), Adware (muestra anuncios no deseados), Ransomware (cifra datos, exige pago) y Fileless Malware (opera en memoria usando herramientas del sistema, no deja archivos en disco).

209. Ransomware — Malware que cifra los archivos de la víctima o bloquea los sistemas, exigiendo un rescate (generalmente en criptomoneda) por las claves de descifrado. Las variantes modernas usan doble extorsión: amenazan con filtrar los datos robados si no se paga.

210. Advanced Persistent Threat (APT) — Una campaña de ataque sofisticada y prolongada, típicamente por actores bien financiados (a menudo de estados-nación), que mantiene acceso no detectado durante períodos extendidos. Usa múltiples vectores, malware personalizado e ingeniería social.

211. Supply Chain Attack — Comprometer a un proveedor externo de confianza o componente de software para atacar a los objetivos finales. Ejemplos notables: SolarWinds (2020), Codecov y 3CX (2023).

212. Zero-Day Vulnerability / Exploit — Una falla previamente desconocida para la que no existe parche. 'Zero-day' = los desarrolladores han tenido cero días para corregirla. Muy valorada tanto por atacantes como por brokers de vulnerabilidades.

213. Botnet — Una red de dispositivos comprometidos (bots/zombis) controlados remotamente mediante infraestructura C2. Usada para DDoS, spam, distribución de malware, criptominería y relleno de credenciales a escala.

214. Command and Control (C2/C&C) — Infraestructura y canales usados para gestionar sistemas comprometidos: emitir comandos, exfiltrar datos, desplegar malware. Puede usar HTTP/S, tunelización DNS, redes sociales o protocolos cifrados.

215. DDoS (Distributed Denial of Service) — Múltiples sistemas comprometidos inundan un objetivo con tráfico, dejándolo no disponible. Ataca el ancho de banda, los recursos del servidor o las capas de aplicación. Se mide en Gbps o solicitudes/segundo.

216. Backdoor — Un método encubierto para eludir la autenticación, instalado por desarrolladores para mantenimiento o implantado por atacantes. Proporciona acceso persistente, a menudo no detectado.

217. Keylogger — Software o hardware que registra las pulsaciones del teclado para capturar contraseñas, números de tarjetas y datos sensibles. Las variantes de software se ejecutan como procesos ocultos; las variantes de hardware se adjuntan a los teclados.

Términos Emergentes 2024–2025

218. AI-Powered Attacks — Ciberataques potenciados por IA/ML: phishing generado por IA, descubrimiento automatizado de vulnerabilidades, malware evasivo adaptativo, reconocimiento asistido por IA e ingeniería social con deepfakes. Reduce el esfuerzo del atacante mientras aumenta la escala y sofisticación.

219. Prompt Injection — Manipulación de una aplicación de LLM mediante entradas elaboradas para eludir las salvaguardas de seguridad o producir resultados no deseados. Directa (el usuario proporciona el prompt malicioso) o indirecta (instrucciones maliciosas incrustadas en datos que el LLM procesa). Clasificado como riesgo #1 en el OWASP Top 10 para Aplicaciones LLM (2025).

220. LLM Security — La disciplina de defenderse contra las amenazas específicas de las aplicaciones de Large Language Model: inyección de prompts, divulgación de información sensible, envenenamiento de datos de entrenamiento, robo de modelos, agencia excesiva y riesgos de la cadena de suministro en los componentes del modelo.

221. OWASP Top 10 for LLM Applications (2025) — Lista impulsada por la comunidad de los riesgos críticos de LLM: LLM01-Inyección de Prompts, LLM02-Divulgación de Información Sensible, LLM03-Cadena de Suministro, LLM04-Envenenamiento de Datos y Modelos, LLM05-Manejo Incorrecto de Salidas, LLM06-Agencia Excesiva, LLM07-Filtración del Prompt del Sistema, LLM08-Debilidades en Vectores e Incrustaciones, LLM09-Desinformación, LLM10-Consumo Ilimitado.

222. Adversarial Machine Learning — Explotar las vulnerabilidades de los modelos de ML mediante ataques de evasión (causando clasificación errónea), envenenamiento de datos (corrompiendo los datos de entrenamiento), extracción de modelos (robando parámetros) y ataques de inferencia (extrayendo datos privados de entrenamiento).

223. Model Poisoning — Manipular los pesos o la arquitectura de un modelo entrenado para introducir backdoors ocultos o salidas sesgadas mientras se mantiene un rendimiento normal en entradas estándar. Demostrado por el ataque PoisonGPT en modelos de código abierto.

224. Data Poisoning — Corromper los datos de entrenamiento para hacer que un modelo aprenda patrones incorrectos. Puede ser dirigido (afectando entradas específicas) o indiscriminado.

225. Deepfake-based Social Engineering — Usar audio, vídeo o imágenes sintéticas generadas por IA para suplantar a personas de confianza con fines de fraude o acceso no autorizado. Incluye llamadas de voz deepfake autorizando transferencias bancarias e impersonación en vídeo en reuniones virtuales.

226. AI Red Teaming — Pruebas adversariales estructuradas de sistemas de IA para descubrir vulnerabilidades, problemas de seguridad y comportamientos no deseados. Prueba inyección de prompts, envenenamiento de datos, sesgo y salidas dañinas. Formalizado por CISA, NIST y las principales empresas de IA.

227. Shadow AI — Uso no autorizado de herramientas de IA (ChatGPT, Claude, Midjourney) por empleados sin supervisión de TI/seguridad. Crea riesgos de filtración de datos, violaciones de cumplimiento y expansión incontrolada de la superficie de ataque. La investigación de IBM en 2025 encontró que la Shadow AI estuvo involucrada en el 20% de las brechas de datos a nivel global.

228. Post-Quantum Cryptography (PQC) — Algoritmos seguros tanto contra computadoras clásicas como cuánticas. En agosto de 2024, NIST finalizó tres estándares PQC: FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) y FIPS 205 (SLH-DSA). La migración es urgente para contrarrestar las amenazas de 'recopilar ahora, descifrar después'.

229. Passkeys / FIDO2 — Credenciales resistentes al phishing y sin contraseña basadas en el estándar FIDO2 (WebAuthn + CTAP2). Usan criptografía de clave pública con la clave privada en el dispositivo del usuario, desbloqueada mediante biometría o PIN. Sincronizadas entre dispositivos a través de servicios en la nube, eliminando completamente las contraseñas.

230. Confidential Computing — Protege los datos en uso realizando cómputos dentro de Entornos de Ejecución Confiable (TEEs) basados en hardware: enclaves seguros de CPU aislados del sistema operativo, el hipervisor y el proveedor de nube. Complementa el cifrado en reposo y en tránsito.

231. CTEM (Continuous Threat Exposure Management) — Un marco de Gartner (Alcance → Descubrir → Priorizar → Validar → Movilizar) para identificar y remediar continuamente las exposiciones en toda la superficie de ataque. A diferencia del escaneo periódico, valida la explotabilidad en el mundo real. Gartner predice una reducción de dos tercios en brechas para 2026 para los adoptantes.

232. Attack Surface Management (ASM) — Descubrir, inventariar y monitorear continuamente todos los activos orientados a internet e internos, incluyendo Shadow IT, para identificar y reducir posibles puntos de ataque. Un insumo clave para los programas CTEM.

233. Cybersecurity Mesh Architecture (CSMA) — Una arquitectura componible introducida por Gartner que permite la interoperabilidad entre herramientas de seguridad dispares a través de cuatro capas: Analítica e Inteligencia, Tejido de Identidad Distribuida, Gestión de Políticas Consolidada y Paneles de Control Integrados. Adecuada para entornos híbridos multi-nube y distribuidos.

234. Identity Threat Detection and Response (ITDR) — Un marco (acuñado por Gartner, 2022) para detectar ataques basados en identidad: robo de credenciales, escalación de

privilegios, mal uso de identidades comprometidas, en tiempo real. Complementa IAM y PAM con análisis conductual y respuesta automatizada.

235. Secure by Design — Una iniciativa impulsada por CISA que integra la seguridad en cada fase del SDLC desde el principio: configuraciones seguras por defecto, eliminación de clases de vulnerabilidades, transparencia y responsabilidad trasladada a los fabricantes de software.

236. Software Bill of Materials (SBOM) — Un inventario legible por máquina de todos los componentes, bibliotecas y dependencias en una aplicación de software. Exigido por la Orden Ejecutiva de EE.UU. 14028 (2021). Permite la identificación rápida de exposición a nuevas vulnerabilidades (por ejemplo, Log4j). Formatos comunes: SPDX y CycloneDX.

Conclusión

Este glosario de 236 términos mapea el panorama completo de la seguridad informática tal como se presenta en 2025, desde los fundamentos atemporales como la tríada CIA y la defensa en profundidad hasta las nuevas fronteras de la criptografía post-cuántica, la seguridad de LLM y el AI Red Teaming. Tres patrones destacan. Primero, el límite entre ofensiva y defensa es cada vez más fluido: los Purple Teams, CTEM y ASM reflejan una profesión que ya no trata el ataque y la defensa como disciplinas separadas. Segundo, la identidad se ha convertido en el nuevo perímetro: el auge de ZTA, ZTNA, ITDR, PAM y Passkeys/FIDO2 muestra que la confianza ya no se otorga por ubicación en la red, sino que se verifica continuamente por solicitud. Tercero, la IA es simultáneamente el nuevo arma más poderosa y la nueva superficie de ataque más novedosa: términos como prompt injection, shadow AI y adversarial ML no existían en la mayoría de los planes de estudio hace dos años, pero ahora son conocimientos esenciales.